

SecChangeLog

Sistem Pencatatan Perubahan Konfigurasi Cyber Security

Complete System Documentation

Version 1.0.0 | Generated: 2026-08-06

Daftar Isi

1. Product Requirements Document (PRD)
2. System Architecture Document
3. Database Schema Design
4. API Specification
5. Security & OWASP Compliance Document
6. Deployment & Operations Guide

Product Requirements Document (PRD)

SecChangeLog — Sistem Pencatatan Perubahan Konfigurasi Cyber Security

Field	Value
Document Version	1.0.0
Status	Final
Author	Engineering Team
Last Updated	2026-08-06
Reviewers	Head of Cyber Security, IT Manager

1. Ringkasan Eksekutif

SecChangeLog adalah sistem pencatatan perubahan konfigurasi perangkat jaringan dan keamanan yang dirancang khusus untuk tim Cyber Security. Sistem ini mencatat seluruh aktivitas perubahan konfigurasi pada perangkat seperti Switch, Router MikroTik, Firewall Palo Alto, dan perangkat lainnya, lengkap dengan bukti screenshot sebelum dan sesudah perubahan.

Sistem dibangun dengan standar keamanan OWASP, mendukung autentikasi lokal maupun LDAP, serta menyediakan audit trail yang lengkap untuk kebutuhan compliance (ISO 27001, PCI-DSS, SOC 2).

2. Latar Belakang & Masalah

Tim Cyber Security rutin melakukan perubahan konfigurasi pada berbagai perangkat (switch, router, firewall). Saat ini pencatatan dilakukan manual via spreadsheet atau chat, yang menyebabkan:

- Tidak ada audit trail yang reliable** — sulit melacak siapa mengubah apa, kapan, dan mengapa
- Bukti perubahan hilang** — screenshot tersebar di chat/email, sulit ditemukan saat audit
- Tidak ada rollback plan terdokumentasi** — saat terjadi insiden, sulit memutar balik perubahan
- Sulit menghasilkan laporan compliance** — tidak ada single source of truth
- Risiko keamanan** — perubahan tidak terdokumentasi = celah untuk audit forensik

3. Tujuan & Sasaran

Tujuan Utama

- Menyediakan single source of truth untuk seluruh perubahan konfigurasi perangkat cyber security
- Memastikan setiap perubahan terdokumentasi dengan bukti visual (screenshot before/after)
- Memfasilitasi audit compliance dengan export laporan terstruktur
- Mencegah penghapusan catatan tanpa persetujuan supervisor

Sasaran Terukur

- 100% perubahan konfigurasi tercatat dalam sistem dalam "d 24 jam setelah implementasi
- Waktu pencarian riwayat perubahan turun dari rata-rata 30 menit menjadi < 30 detik

- Laporan audit bulanan dapat di-generate dalam < 5 menit
- Penghapusan catatan membutuhkan persetujuan supervisor (zero unauthorized deletion)

4. Stakeholder & User Personas

Role	Deskripsi	Permission
Engineer	Anggota tim yang melakukan perubahan	Create, read, update own records; cannot
Supervisor	Penanggung jawab yang menyetujui	All engineer permissions + approve/reject
Admin	Administrator sistem	Full access, manage users, manage device
Auditor (read-only)	Auditor internal/eksternal	Read-only access untuk semua catatan &

5. Functional Requirements

5.1 Authentication & User Management

- ****FR-AUTH-01****: Sistem mendukung login dengan username/password (bcrypt hashing)
- ****FR-AUTH-02****: Sistem mendukung autentikasi via LDAP/Active Directory (configurable)
- ****FR-AUTH-03****: Session management dengan JWT, expiry 8 jam, refresh token mechanism
- ****FR-AUTH-04****: Password policy: minimum 10 karakter, kombinasi huruf besar/kecil/angka/symbol
- ****FR-AUTH-05****: Account lockout setelah 5 percobaan gagal selama 15 menit
- ****FR-AUTH-06****: Admin dapat CRUD user accounts
- ****FR-AUTH-07****: Role-based access control (RBAC): Engineer, Supervisor, Admin, Auditor

5.2 Change Log Management

- ****FR-CHG-01****: Engineer dapat membuat change log baru dengan field:
 - Ticket ID (auto-generate format: `CHG-YYYY-NNNN`)
 - Tanggal & waktu perubahan
 - Jenis perangkat (dynamic, configurable dari admin settings)
 - Nama/host perangkat
 - IP address perangkat
 - Jenis perubahan (ACL, Routing, NAT, Interface, Security Policy, VPN, DLL)
 - Deskripsi perubahan (before !' after)
 - Alasan perubahan
 - Risk level (Low / Medium / High / Critical)
 - PIC engineer
 - Rollback plan
 - Status (Draft / Implemented / Verified)
- ****FR-CHG-02****: Engineer dapat upload multiple screenshot bukti (before & after)
- ****FR-CHG-03****: Engineer dapat edit catatan sendiri selama status masih Draft
- ****FR-CHG-04****: Setelah status Implemented, catatan terkunci (read-only) kecuali oleh Admin
- ****FR-CHG-05****: Sistem mencatat audit trail: siapa, kapan, apa yang diubah

5.3 Delete Approval Workflow

- **FR-DEL-01***: Engineer dapat mengajukan request hapus catatan
- **FR-DEL-02***: Request hapus masuk ke antrian persetujuan supervisor
- **FR-DEL-03***: Supervisor dapat approve atau reject request hapus
- **FR-DEL-04***: Setelah approve, catatan di-soft delete (tetap ada di DB, marked as deleted)
- **FR-DEL-05***: Hanya Admin yang dapat hard delete (permanent) untuk keperluan housekeeping
- **FR-DEL-06***: Sistem mencatat siapa yang request, approve, dan eksekusi penghapusan

5.4 Device Type Management

- **FR-DEV-01***: Admin dapat menambah jenis perangkat baru (selain Switch/MikroTik/Palo Alto)
- **FR-DEV-02***: Setiap perangkat dapat memiliki field konfigurasi kustom (optional)
- **FR-DEV-03***: Device type dapat diaktifkan/nonaktifkan (tidak bisa dihapus jika masih digunakan)

5.5 Settings & Customization

- **FR-SET-01***: Admin dapat mengubah nama sistem (system name)
- **FR-SET-02***: Admin dapat upload custom logo (PNG/SVG, max 2MB)
- **FR-SET-03***: Admin dapat mengubah default theme (light/dark)
- **FR-SET-04***: Admin dapat mengatur LDAP configuration
- **FR-SET-05***: Admin dapat mengatur password policy

5.6 Dashboard & Analytics

- **FR-DASH-01***: Dashboard menampilkan statistik: total change logs, per bulan, per perangkat, per PIC, per risk level
- **FR-DASH-02***: Grafik trend perubahan 30 hari terakhir
- **FR-DASH-03***: Recent activity feed
- **FR-DASH-04***: Pending deletion approvals (untuk supervisor)

5.7 Search & Filter

- **FR-SRCH-01***: Search by Ticket ID, device name, IP, PIC, description
- **FR-SRCH-02***: Filter by date range, device type, risk level, status, PIC
- **FR-SRCH-03***: Sort by any column (ascending/descending)
- **FR-SRCH-04***: Pagination (default 20 per page, max 100)

5.8 Reporting & Export

- **FR-RPT-01***: Export list change logs ke Excel (.xlsx) dengan filter aktif
- **FR-RPT-02***: Export detail single change log ke PDF (termasuk screenshot)
- **FR-RPT-03***: Export monthly summary report ke PDF
- **FR-RPT-04***: Export audit trail log ke Excel

6. Non-Functional Requirements

6.1 Security (OWASP Top 10 Compliance)

- **NFR-SEC-01***: Protection against SQL Injection (Prisma parameterized queries)
- **NFR-SEC-02***: Protection against XSS (React auto-escaping + CSP headers)
- **NFR-SEC-03***: Protection against CSRF (SameSite cookies + CSRF tokens)
- **NFR-SEC-04***: Protection against brute force (rate limiting + account lockout)
- **NFR-SEC-05***: Secure password hashing (bcrypt, cost factor 12)
- **NFR-SEC-06***: HTTPS-only in production (HSTS headers)
- **NFR-SEC-07***: Security headers: X-Frame-Options, X-Content-Type-Options, Referrer-Policy
- **NFR-SEC-08***: File upload validation: type whitelist (PNG/JPEG/PDF), size limit, magic number validation
- **NFR-SEC-09***: No sensitive data in logs
- **NFR-SEC-10***: Input validation on all API endpoints (Zod schemas)

6.2 Performance

- **NFR-PERF-01***: Page load < 2 detik (First Contentful Paint)
- **NFR-PERF-02***: API response < 500ms untuk query biasa
- **NFR-PERF-03***: Support 50 concurrent users
- **NFR-PERF-04***: File upload max 10MB per file, 50MB per request

6.3 Availability

- **NFR-AVL-01***: Uptime target 99.5% (business hours)
- **NFR-AVL-02***: Daily database backup
- **NFR-AVL-03***: Graceful error handling, no white screen

6.4 Usability

- ****NFR-USE-01****: Responsive design (mobile, tablet, desktop)
- ****NFR-USE-02****: Dark theme default dengan toggle light theme
- ****NFR-USE-03****: Keyboard accessible (WCAG 2.1 AA)
- ****NFR-USE-04****: Bahasa Indonesia untuk UI labels

6.5 Maintainability

- ****NFR-MAIN-01****: Code coverage > 70% untuk business logic
- ****NFR-MAIN-02****: TypeScript strict mode
- ****NFR-MAIN-03****: ESLint + Prettier enforced
- ****NFR-MAIN-04****: Dokumentasi inline untuk semua API endpoints

7. Tech Stack

Layer	Technology	Alasan
Frontend	Next.js 16 (App Router) + React 19	SSR, file-based routing, modern
UI	Tailwind CSS 4 + shadcn/ui + Lucide icons	Konsistensi visual, aksesibilitas
State	Zustand (client) + TanStack Query (server)	Lightweight, performant
Backend	Next.js API Routes + Server Actions	Single codebase, type-safe
ORM	Prisma 6	Type-safe, migration support
Database	MySQL 8 (production) / SQLite (sandbox)	Sesuai request, MySQL untuk production
Auth	NextAuth.js v4 + bcrypt + LDAP adapter	Flexible, secure
File Storage	Local filesystem (`/uploads`)	Sesuai request, bisa di-upgrade ke S3
Charts	Recharts	React-native, responsive
Export	`xlsx` (Excel) + `pdfkit`/`puppeteer` (PDF)	Standar industri
Validation	Zod	

8. Data Model (High-Level)

Detail lengkap di dokumen `03-Database-Schema.md`.

****Entities utama:****

- User (id, email, name, role, passwordHash, ldapDn?, ...)
 - DeviceType (id, name, isActive, ...)
 - ChangeLog (id, ticketId, deviceId, deviceType, changeType, description, ...)
 - Screenshot (id, changeLogId, filename, mimeType, size, type [before/after], ...)
 - DeleteRequest (id, changeLogId, requestedBy, status, approvedBy?, ...)
 - AuditTrail (id, userId, action, entityType, entityId, metadata, timestamp)
 - SystemSetting (key, value) — untuk nama sistem, logo, theme, LDAP config
 - Session (NextAuth managed)
-

9. User Flow Utama

9.1 Engineer Mencatat Perubahan

Login !' Klik "New Change Log" !' Isi form (device, change type, before/after, alasan, risk, rollback plan) !' Upload screenshot before !' Upload screenshot after !' Submit !' Catatan tersimpan dengan status "Implemented" !' Audit trail tercatat

9.2 Engineer Request Hapus Catatan

Buka change log !' Klik "Request Delete" !' Isi alasan !' Submit !' Request masuk antrian supervisor !' Engineer dapat lihat status request di "My Deletion Requests"

9.3 Supervisor Approve/Reject Delete

Login !' Dashboard menampilkan badge "Pending Delete Approvals" !' Buka "Delete Requests" !' Review detail !' Approve atau Reject dengan komentar !' Catatan di-soft delete (jika approve) !' Audit trail tercatat

9.4 Auditor Export Laporan

Login !' Buka list change logs !' Apply filter (date range, device, PIC) !' Klik "Export to Excel" !' File .xlsx diunduh

9.5 Admin Custom Sistem

Login !' Settings !' Upload logo baru !' Ganti system name !' Set default theme !' Save !' Perubahan langsung tampil di seluruh UI

10. Out of Scope (MVP)

Berikut fitur yang ****TIDAK**** termasuk dalam MVP v1:

- Integrasi auto-pull config dari perangkat (SSH/Telnet automation)
 - Real-time notification (email/Slack) — akan di v2
 - Multi-tenant organization support
 - Mobile app native
 - Single Sign-On dengan SAML/OAuth (LDAP sudah cukup untuk v1)
 - Approval workflow untuk create change (hanya deletion yang perlu approval)
 - Version diff visualization untuk config text
-

11. Acceptance Criteria

MVP dinyatakan selesai jika:

- [] User dapat register, login, logout dengan aman
- [] Engineer dapat membuat, melihat, edit (draft) change log
- [] Engineer dapat upload screenshot before/after (multiple files)
- [] Engineer dapat request delete, supervisor dapat approve/reject
- [] Soft delete berfungsi, audit trail tercatat
- [] Admin dapat CRUD device types
- [] Admin dapat mengubah nama sistem & upload logo
- [] Dashboard menampilkan statistik & grafik dengan benar
- [] Search & filter berfungsi dengan pagination
- [] Export Excel berfungsi dengan filter aktif
- [] Export PDF per change log berfungsi (termasuk screenshot)

- [] Light/Dark theme berfungsi (default dark)
- [] LDAP configuration tersedia (dapat di-enable/disable)
- [] Tidak ada vulnerability OWASP Top 10 yang critical/high
- [] Aplikasi berjalan di production build tanpa error

12. Risk & Mitigation

Risk	Likelihood	Impact	Mitigation
Data loss (database corruption)	Low	Critical	Daily backup, transaction
Unauthorized access	Medium	Critical	bcrypt + RBAC + audit trail
Malicious file upload	Medium	High	Magic number validation, size
LDAP server down	Low	Medium	Fallback ke local auth, log
Screenshot storage penuh	Medium	Medium	Monitoring disk usage, archive

13. Timeline & Milestones

Phase	Deliverable	Duration
Phase 1	Documentation (PRD, architecture, API,	1 day
Phase 2	Database schema, auth, base UI	1 day
Phase 3	Change log CRUD + upload + delete	1 day
Phase 4	Settings, dashboard, export	0.5 day

14. Glossary

- **Change Log**: Catatan satu kali perubahan konfigurasi pada perangkat
- **PIC**: Person In Charge — engineer yang melakukan perubahan
- **Risk Level**: Tingkat risiko perubahan (Low/Medium/High/Critical)
- **Rollback Plan**: Rencana membatalkan perubahan jika terjadi masalah
- **Audit Trail**: Log lengkap aktivitas user untuk forensik & compliance
- **Soft Delete**: Data ditandai deleted tetapi tidak benar-benar dihapus dari DB
- **RBAC**: Role-Based Access Control — kontrol akses berbasis peran user
- **OWASP**: Open Web Application Security Project — standar keamanan aplikasi web

SecChangeLog — Sistem Pencatatan Perubahan Konfigurasi

1. Arsitektur High-Level

[illegible]

```

/home/z/my-project/
% % % docs/ # Dokumentasi profesional
% % % 01-PRD.md
% % % 02-Architecture.md
% % % 03-Database-Schema.md
% % % 04-API-Specification.md
% % % 05-Security-OWASP.md
% % % 06-Deployment-Guide.md
% % % prisma/
% % % schema.prisma # Database schema (single source)
% % % src/
% % % app/
% % % (auth)/ # Login, register pages
% % % login/page.tsx
% % % layout.tsx

```

```

% % % % (dashboard)/ # Protected pages
% % % % % page.tsx # Dashboard utama
% % % % % logs/
% % % % % % % % page.tsx # List change logs
% % % % % % % % new/page.tsx # Form create
% % % % % % % % [id]/
% % % % % % % % page.tsx # Detail
% % % % % % % % edit/page.tsx
% % % % % % % % delete-requests/page.tsx
% % % % % % % % audit-trail/page.tsx
% % % % % % % % users/page.tsx # Admin only
% % % % % % % % settings/page.tsx # Admin only
% % % % % % % % api/
% % % % % % % % auth/[...nextauth]/route.ts
% % % % % % % % change-logs/route.ts
% % % % % % % % change-logs/[id]/route.ts
% % % % % % % % upload/route.ts
% % % % % % % % delete-requests/route.ts
% % % % % % % % delete-requests/[id]/approve/route.ts
% % % % % % % % export/excel/route.ts
% % % % % % % % export/pdf/[id]/route.ts
% % % % % % % % admin/
% % % % % % % % device-types/route.ts
% % % % % % % % users/route.ts
% % % % % % % % settings/route.ts
% % % % % % % % layout.tsx # Root layout (Theme provider, Toaster)
% % % % % % % % globals.css # Global styles + CSS variables
% % % % % % % % components/
% % % % % % % % ui/ # shadcn/ui components
% % % % % % % % layout/ # Sidebar, Header, Footer
% % % % % % % % change-logs/ # Domain components
% % % % % % % % dashboard/ # Dashboard widgets
% % % % % % % % settings/ # Settings components
% % % % % % % % shared/ # Shared widgets
% % % % % % % % lib/
% % % % % % % % db.ts # Prisma client singleton
% % % % % % % % auth.ts # NextAuth config
% % % % % % % % auth-options.ts
% % % % % % % % ldap.ts # LDAP adapter
% % % % % % % % validations/ # Zod schemas
% % % % % % % % change-log.ts
% % % % % % % % user.ts
% % % % % % % % settings.ts
% % % % % % % % services/ # Business logic
% % % % % % % % change-log.service.ts
% % % % % % % % delete-request.service.ts
% % % % % % % % audit-trail.service.ts
% % % % % % % % file-storage.service.ts
% % % % % % % % export.service.ts
% % % % % % % % auth.service.ts
% % % % % % % % security/ # Security utilities
% % % % % % % % rate-limit.ts
% % % % % % % % password.ts
% % % % % % % % file-validation.ts
% % % % % % % % headers.ts
% % % % % % % % constants.ts
% % % % % % % % utils.ts
% % % % % % % % session.ts # Server-side session helper
% % % % % % % % types/
% % % % % % % % next-auth.d.ts # Augment NextAuth types
% % % % % % % % index.ts
% % % % % % % % middleware.ts # Auth + security headers
% % % % % % % % providers/
% % % % % % % % theme-provider.tsx
% % % % % % % % query-provider.tsx
% % % % % % % % public/
% % % % % % % % uploads/ # User-uploaded files (gitignored)
% % % % % % % % screenshots/
% % % % % % % % logos/
% % % % % % % % prisma/
% % % % % % % % schema.prisma

```

```
% % % scripts/           # Build/maintenance scripts
% % % tests/             # Test files
% % % .env.example
% % % README.md
% % % package.json
```

4. Komponen Arsitektur Detail

4.1 Middleware (Edge Runtime)

- Cek JWT token di cookie untuk route protected
- Rate limiting berbasis IP (in-memory Map untuk single instance)
- Inject security headers (CSP, HSTS, X-Frame-Options, dll.)
- Redirect unauthenticated users ke `/login`

4.2 NextAuth Configuration

- Strategy: JWT dengan database session fallback
- Providers: Credentials (local) + LDAP (optional, configurable via SystemSettings)
- Callbacks:
 - `jwt`: inject role & permissions ke token
 - `session`: expose role ke client session
- Pages: custom `/login`
- Session expiry: 8 jam
- Cookie: `httpOnly`, `secure` (production), `sameSite: 'lax'`

4.3 Service Layer Pattern

Setiap service mengikuti pola:

```
// Pure functions, tidak bergantung pada HTTP context
export class ChangeLogService {
  static async create(input: CreateChangeLogInput, userId: string): Promise<ChangeLog> {
    // 1. Validate (Zod)
    // 2. Business rules check
    // 3. DB transaction (Prisma)
    // 4. Write AuditTrail
    // 5. Return result
  }
}
```

4.4 File Storage Strategy

- Lokasi: `/home/z/my-project/public/uploads/`
- Struktur: `screenshots/{changeLogId}/{uuid}.{ext}` dan `logos/system-logo.{ext}`
- Validasi:
 - MIME type whitelist: `image/png`, `image/jpeg`, `image/webp`, `application/pdf`
 - Magic number verification (tidak percaya Content-Type header)
 - Max size: 10MB per file
 - Filename sanitization: hanya alphanumeric + dash
 - **Path traversal prevention**: selalu generate UUID filename, tidak pernah pakai user-supplied filename

4.5 Audit Trail Mechanism

Setiap mutasi data menulis ke tabel `AuditTrail`:

```
{
  userId, action: 'CREATE_CHANGE_LOG' | 'UPDATE_CHANGE_LOG' | 'DELETE_REQUEST' | ...,
  entityType: 'ChangeLog' | 'User' | 'DeviceType' | ...,
  entityId: string,
  metadata: JSON (before/after diff),
  timestamp, ipAddress, userAgent
}
```

4.6 Export Pipeline

- **Excel**: gunakan `xlsx` library, generate in-memory, stream sebagai response
- **PDF**: gunakan `pdfkit` (lebih ringan) atau `puppeteer` (jika butuh HTML rendering kompleks)
- Untuk MVP, gunakan `pdfkit` dengan layout custom (header, content, screenshot embedded)

5. Security Architecture

5.1 Authentication Flow

```
[Login Form] !' POST /api/auth/callback/credentials
              !' Verify credentials (local DB or LDAP)
              !' Generate JWT (8h expiry)
              !' Set httpOnly cookie
              !' Return user profile to client
```

5.2 Authorization Matrix

Resource	Engineer	Supervisor	Admin	Auditor
Dashboard	Own data	All	All	All (read)
Change Logs	CRUD own	Read all	CRUD all	Read all
Delete Request	Create own	Approve/Reject	All	Read
Users	Read self	Read self	CRUD all	Read all
Device Types	Read	Read	CRUD	Read
Settings	Read (limited)	Read (limited)	CRUD	Read
Audit Trail	Read own	Read all	Read all	Read all
Export	Own data	All	All	All

5.3 Input Validation Strategy

- **Client-side**: React Hook Form + Zod resolver (UX)
- **Server-side API**: Zod schema parse (mandatory)
- **Server Action**: Zod schema parse (mandatory)
- **Database**: Prisma type-safe queries (final defense)

5.4 File Upload Security Pipeline

1. Check authentication (middleware)
 2. Check authorization (role-based)
 3. Check content-length ("d 10MB)
 4. Stream to memory with size limit
 5. Verify magic number (PNG: 89504E47, JPEG: FFD8FF, PDF: 25504446)
 6. Re-encode image with sharp (strip EXIF + metadata)
 7. Save dengan UUID filename
 8. Return safe URL
-

6. Database Strategy

6.1 Production: MySQL 8

- Engine: InnoDB (transaction support, row-level locking)
- Charset: `utf8mb4` (full Unicode support, including emoji)
- Collation: `utf8mb4\_unicode\_ci`
- Connection pool: Prisma connection pool (default 10, configurable)

6.2 Development/Sandbox: SQLite

- File-based, zero config
- Schema identik (Prisma abstraction)
- Untuk demo & development

> **Catatan**: Karena sandbox environment terbatas, kita akan menggunakan SQLite untuk demo, tetapi schema Prisma dirancang agar compatible dengan MySQL 8 (menggunakan tipe data yang supported di kedua DB). Lihat `03-Database-Schema.md` untuk detail migration path.

6.3 Backup Strategy (Production)

- Daily full backup (mysqldump, cron 02:00)
 - Binary log untuk point-in-time recovery
 - Retention: 30 hari
 - Backup di-encrypt dengan GPG sebelum dikirim ke offsite storage
-

7. Performance Considerations

7.1 Database Indexing

- Index pada kolom yang sering di-filter: `ticketId`, `deviceType`, `riskLevel`, `status`, `picId`, `createdAt`
- Composite index untuk query umum: `(deviceType, createdAt)`, `(status, createdAt)`
- Full-text search (MySQL) untuk kolom `description` (production-only)

7.2 Caching Strategy

- TanStack Query cache di client (stale-while-revalidate, 60s default)
- Revalidate tag-based untuk Server Components (60s)
- Tidak menggunakan Redis di MVP (in-memory sudah cukup untuk 50 concurrent users)

7.3 Image Optimization

- Gunakan Next.js `` component untuk automatic optimization
- `sharp` untuk re-encode upload (strip metadata, resize jika > 1920px)
- Lazy load screenshot di list view

7.4 Bundle Size

- Code splitting per route (App Router automatic)
 - Tree-shaking untuk library besar
 - Dynamic import untuk export libraries (xlsx, pdfkit) — hanya load saat dibutuhkan
-

8. Error Handling Strategy

AppError (base)

8.2 Error Response Format

8.3 Logging

- ## 9. Deployment Architecture

[illegible]

- Nginx/Caddy di depan Next.js
- SSL termination (Let's Encrypt)
- Gzip compression
- Static file caching

- Dockerfile multi-stage build
- docker-compose.yml dengan services: app, mysql
- Volume untuk uploads dan mysql data

10. Monitoring & Observability

- Endpoint: ``GET /api/health` !` { status: 'ok', db: 'connected', uptime: ... }`
- Database connectivity check
- Disk space check untuk uploads folder

- Request/response logging (method, path, status, duration)
- Error logging dengan stack trace

- Audit trail di database (untuk compliance)

10.3 Metrics (Future)

- Application metrics: request count, response time, error rate
- Business metrics: change logs per day, active users
- Database metrics: connection pool, slow queries

11. Scalability Path (Future)

Untuk MVP, single server sudah cukup. Jika butuh scale:

1. **Vertical scaling**: upgrade server RAM/CPU
2. **Horizontal scaling**:
 - Stateless app instances di belakang load balancer
 - Shared session via database (bukan cookie JWT)
 - Move uploads ke S3-compatible storage
3. **Database scaling**:
 - Read replicas untuk query berat
 - Connection pooling via PgBouncer/ProxySQL

12. Technology Decision Log

Decision	Choice	Alternatives Considered	Reason
Framework	Next.js 16	Remix, Nuxt	App Router, RSC, ecosystem
Database	MySQL 8	PostgreSQL, SQLite	User request, familiar, ACID
ORM	Prisma 6	Drizzle, TypeORM	Type-safe, best DX, migration
Auth	NextAuth.js	Lucia, custom	Battle-tested, LDAP-ready via
UI Library	shadcn/ui	MUI, Ant Design	Modern, customizable, copy-
State	Zustand + TanStack Query	Redux Toolkit	Simpler, less boilerplate
Charts	Recharts	Chart.js, Nivo	React-native, declarative

Database Schema Design

SecChangeLog — Sistem Pencatatan Perubahan Konfigurasi

Field	Value
Document Version	1.0.0
Status	Final
Last Updated	2026-08-06
DBMS Target	MySQL 8.0+ (production), SQLite (sandbox)

1. Diagram ERD (Entity Relationship)

[illegible]

```

%                               %¼
%                               % % % % % % % % % % % % % % % %
%                               %       Screenshot       %
%                               % % % % % % % % % % % % % % % %$
%                               % id (PK)                  %
%                               % changeLogId (FK)         %
%                               % filename                 %
%                               % originalName             %
%                               % mimeType                 %
%                               % size                     %
%                               % type (before/after)%
%                               % createdAt                %
%                               % % % % % % % % % % % % % % % %
%
% 1..N                      % % % % % % % % % % % % % % % %
% % % % % % % % % % % % % % % % DeleteRequest %
% (requester)              % % % % % % % % % % % % % % % %$
%                               % id (PK)                  %
%                               % changeLogId (FK)         %
%                               % requestedById(FK)%
%                               % reason                   %
%                               % status                   %
%                               % approvedById?           %
%                               % approvedAt?              %
%                               % approverNote?            %
%                               % createdAt                %
%                               % updatedAt                %
%                               % % % % % % % % % % % % % % % %
%
% 1..N                      % % % % % % % % % % % % % % % %
% % % % % % % % % % % % % % % % AuditTrail %
%                               % % % % % % % % % % % % % % % %$
%                               % id (PK)                  %
%                               % userId (FK)              %
%                               % action                   %
%                               % entityType               %
%                               % entityId                 %
%                               % metadata (JSON)          %
%                               % ipAddress                %
%                               % userAgent                %
%                               % timestamp                %
%                               % % % % % % % % % % % % % % % %
% % % % % % % % % % % % % % % %
% SystemSetting %
% % % % % % % % % % % % % % % %$
% id (PK) %
% key (UQ) %
% value (TEXT) %
% updatedAt %
% updatedBy (FK) %
% % % % % % % % % % % % % % % %
% % % % % % % % % % % % % % % %
% Account (NextAuth)%
% % % % % % % % % % % % % % % %$
% id (PK) %
% userId (FK) %
% providerType %
% providerId %
% providerAccountId%
% refreshToken %
% accessToken %
% expiresAt %
% tokenType %
% scope %
% idToken %
% sessionState %
% % % % % % % % % % % % % % % %
% % % % % % % % % % % % % % % %
% Session (NextAuth)%
% % % % % % % % % % % % % % % %$
% id (PK) %

```

%	sessionToken (UQ)%
%	userId (FK) %
%	expires %
%	% %
%	% %
%	VerificationToken%
%	% \$
%	identifier %
%	token (UQ) %
%	expires %
%	% %

2. Detail Tabel

2.1 User

Menyimpan data pengguna sistem. Mendukung autentikasi local (passwordHash) dan LDAP (ldapDn).

Column	Type	Constraints	Description
id	String(cuid)	PK	Unique identifier
email	String	UQ, NOT NULL	Email login (case-insensitive)
name	String	NOT NULL	Display name
passwordHash	String?	nullable	bcrypt hash; null jika pure LDAP
role	Enum	NOT NULL, default 'ENGINEER'	ENGINEER, SUPERVISOR,
ldapDn	String?	nullable	LDAP Distinguished Name
isActive	Boolean	NOT NULL, default true	Soft disable account
failedAttempts	Int	NOT NULL, default 0	Counter untuk logout

- **Indexes:****
- UNIQUE INDEX on `email` (lowercased untuk case-insensitive)
 - INDEX on `role`
 - INDEX on `isActive`

2.2 DeviceType

Jenis perangkat yang dapat dikonfigurasi secara dinamis.

Column	Type	Constraints	Description
id	String(cuid)	PK	
name	String	UQ, NOT NULL	Misal "Switch", "Router"
description	String?		Catatan opsional
isActive	Boolean	NOT NULL, default true	Soft disable
createdAt	DateTime		
updatedAt	DateTime		

- **Seed Data:****
- Switch
 - Router MikroTik
 - Firewall Palo Alto
 - Firewall Fortinet
 - Server Linux
 - Server Windows

2.3 ChangeLog

Catatan inti sistem.

Column	Type	Constraints	Description
id	String(cuid)	PK	
ticketId	String	UQ, NOT NULL	

```
**Indexes:**
• UNIQUE INDEX on `ticketId`
• INDEX on `(deviceTypeId, createdAt)`
• INDEX on `(status, createdAt)`
• INDEX on `(riskLevel, createdAt)`
• INDEX on `picId`
• INDEX on `isDeleted` (partial: WHERE isDeleted = false)
• INDEX on `implementedAt`
```

2.4 Screenshot

File bukti perubahan.

Column	Type	Constraints	Description
id	String(cuid)	PK	
changeLogId	String	FK !' ChangeLog.id, NOT NULL,	
filename	String	NOT NULL	UUID-based filename di disk
originalName	String	NOT NULL	Nama asli file (sanitized)
mimeType	String	NOT NULL	image/png, image/jpeg,
size	Int	NOT NULL	Bytes
type	Enum	NOT NULL	BEFORE, AFTER, OTHER
createdAt	DateTime	NOT NULL, default now()	

```
**Indexes:**
• INDEX on `(changeLogId, type)`
```

2.5 DeleteRequest

Pengajuan penghapusan change log yang butuh approval supervisor.

Column	Type	Constraints	Description
id	String(cuid)	PK	
changeLogId	String	FK !' ChangeLog.id, NOT NULL	
requestedById	String	FK !' User.id, NOT NULL	
reason	String	NOT NULL (text)	Alasan penghapusan
status	Enum	NOT NULL, default 'PENDING'	PENDING, APPROVED,
approvedById	String?	FK !' User.id	
approvedAt	DateTime?		
approverNote	String?	(text)	Catatan approver
createdAt	DateTime	NOT NULL, default now()	
updatedAt	DateTime	NOT NULL, auto	

****Indexes:****

- INDEX on `(status, createdAt)` (untuk query pending approvals)
- INDEX on `requestedById`

- INDEX on `changeLogId`

****Business Rules:****

- Satu change log hanya bisa punya satu `PENDING` delete request
- Setelah approved, `ChangeLog.isDeleted = true` dan `deletedAt = now()`
- Setelah rejected, user tidak bisa request lagi dalam 24 jam

2.6 AuditTrail

Log lengkap aktivitas untuk forensik & compliance.

Column	Type	Constraints	Description
id	String(cuid)	PK	
userId	String	FK !' User.id, NOT NULL	
action	String	NOT NULL	Lihat daftar action di bawah
entityType	String	NOT NULL	ChangeLog, User, DeviceType,
entityId	String	NOT NULL	
metadata	Json		Before/after diff, additional
ipAddress	String?		
userAgent	String?		
timestamp	DateTime	NOT NULL, default now()	

****Action Values:****

- `LOGIN\_SUCCESS`, `LOGIN\_FAILED`, `LOGOUT`
- `CREATE\_CHANGE\_LOG`, `UPDATE\_CHANGE\_LOG`, `VIEW\_CHANGE\_LOG`
- `CREATE\_DELETE\_REQUEST`, `APPROVE\_DELETE\_REQUEST`, `REJECT\_DELETE\_REQUEST`

- `SOFT\_DELETE\_CHANGE\_LOG`, `RESTORE\_CHANGE\_LOG`, `HARD\_DELETE\_CHANGE\_LOG`
- `UPLOAD\_SCREENSHOT`, `DELETE\_SCREENSHOT`
- `CREATE\_USER`, `UPDATE\_USER`, `DEACTIVATE\_USER`, `ACTIVATE\_USER`
- `CREATE\_DEVICE\_TYPE`, `UPDATE\_DEVICE\_TYPE`, `DEACTIVATE\_DEVICE\_TYPE`
- `UPDATE\_SYSTEM\_SETTING`, `UPDATE\_SYSTEM\_LOGO`
- `EXPORT\_EXCEL`, `EXPORT\_PDF`
- `CHANGE\_THEME`

****Indexes:****

- INDEX on `(userId, timestamp)`
- INDEX on `(entityType, entityId)`
- INDEX on `(action, timestamp)`
- INDEX on `timestamp`

2.7 SystemSetting

Key-value store untuk konfigurasi sistem (nama, logo path, theme, LDAP config).

Column	Type	Constraints	Description
id	String(cuid)	PK	
key	String	UQ, NOT NULL	
value	String	NOT NULL (text)	JSON-encoded untuk complex
updatedAt	DateTime	NOT NULL, auto	
updatedById	String	FK !' User.id	

****Default Settings:****

Key	Default Value	Description
`system.name`	`"SecChangeLog"`	Nama sistem
`system.logoPath`	`null`	Path ke custom logo
`system.defaultTheme`	`"dark"`	Default theme

2.8 NextAuth Tables

Mengikuti standar NextAuth.js v4 adapter:

- `Account` (untuk OAuth/LDAP provider link)
- `Session` (jika menggunakan database session strategy)
- `VerificationToken` (untuk email verification flow)

3. Prisma Schema (Reference)

Schema lengkap ada di `prisma/schema.prisma`. Untuk sandbox, menggunakan SQLite provider. Untuk production, ganti ke MySQL:

```
datasource db {
  provider = "mysql" // production
  // provider = "sqlite" // sandbox
  url      = env("DATABASE_URL")
}
```

MySQL-specific notes:

- Gunakan `@db.Text` untuk kolom long text
- Gunakan `@db.VarChar(255)` untuk string dengan limit
- JSON column: `Json` type (MySQL native JSON)
- Index composite dengan `@@index`

4. Data Migration Path

4.1 Sandbox !' Production

1. Export data dari SQLite: `sqlite3 db/app.db .dump > dump.sql`
2. Transform syntax SQLite !' MySQL (sedikit perbedaan)
3. Import ke MySQL: `mysql -u user -p db < dump.sql`
4. Atau lebih mudah: gunakan Prisma seed script untuk copy data via ORM

4.2 Schema Migration

- Selalu gunakan `prisma migrate dev` untuk development
- `prisma migrate deploy` untuk production
- **Backup database sebelum migration di production**

5. Data Retention Policy

Entity	Retention	Action
ChangeLog (active)	7 tahun	Tidak dihapus (compliance)
ChangeLog (soft-deleted)	1 tahun	Hard delete setelah 1 tahun
AuditTrail	7 tahun	Tidak dihapus (compliance)
DeleteRequest	1 tahun setelah resolved	Hard delete
Sessions	Sesuai expiry	Auto-cleaned
User (deactivated)		

****Implementation****: cron job mingguan untuk hard delete data yang sudah expired.

6. Backup & Recovery

6.1 Backup Schedule

- ****Daily full backup****: 02:00 WIB, mysqldump, encrypted dengan GPG
- ****Binary log****: continuous, untuk point-in-time recovery
- ****Offsite copy****: backup dikirim ke S3-compatible storage 03:00 WIB

6.2 Recovery Procedures

- ****RPO (Recovery Point Objective)****: "d 24 jam (daily backup)
- ****RTO (Recovery Time Objective)****: "d 4 jam
- ****Test restore****: bulanan, di staging environment

6.3 Backup Verification

- Setiap backup diverifikasi: restore ke staging, jalankan query test
 - Checksum verification
 - Log backup status ke monitoring
-

7. Performance Considerations

7.1 Query Optimization

- Gunakan Prisma `select` untuk ambil hanya kolom yang dibutuhkan
- Pagination dengan cursor-based (lebih cepat untuk offset besar)
- Eager loading dengan `include` untuk relasi (hindari N+1)
- Count query terpisah (lebih cepat daripada count + data di satu query)

7.2 Index Strategy

- Index dibuat berdasarkan query pattern yang sering dipakai
- Monitor slow query log MySQL
- Composite index untuk filter + sort kombinasi umum

7.3 Connection Pooling

- Prisma default connection pool: `?connection\_limit=10`
 - Production: naikan ke `?connection\_limit=20` sesuai concurrent users
 - Monitor pool usage, slow queries
-

8. Security di Database Level

8.1 Encryption at Rest

- MySQL: enable `innodb\_encrypt\_tables=ON`
- Atau: disk encryption (LUKS untuk Linux)

8.2 Encryption for Sensitive Fields

- `passwordHash`: bcrypt (sudah aman secara design)
- `ldap.bindPassword` di SystemSetting: encrypt dengan AES-256-GCM, key dari env var

8.3 Database User Privileges (Production)

- App user: SELECT, INSERT, UPDATE, DELETE pada schema aplikasi
- Migration user: + CREATE, ALTER, DROP, INDEX (hanya untuk migration)
- Backup user: SELECT + LOCK TABLES

8.4 SQL Injection Prevention

- ****Prisma selalu parameterize queries**** — tidak ada raw SQL injection vector
 - Jika butuh raw SQL (`\$queryRaw`), selalu gunakan tagged template literal: `prisma.\$queryRaw`
`SELECT \* FROM x WHERE id = \${id}`
 - Validasi input tetap dilakukan dengan Zod sebelum query
-

API Specification

SecChangeLog — REST API

Field	Value
Document Version	1.0.0
Status	Final
Last Updated	2026-08-06
Base URL	`/api`

1. Konvensi Umum

1.1 Authentication

- Semua endpoint (kecuali `/api/auth/\*` dan `/api/health`) memerlukan JWT di cookie `next-auth.session-token`
- Token diperoleh dari endpoint login NextAuth

1.2 Request Format

- Content-Type: `application/json` (untuk body)
- Untuk upload file: `multipart/form-data`
- Parameter query: snake_case

1.3 Response Format

****Sukses (2xx):****

```
{
  "data": { ... } | [ ... ] | null,
  "meta": {
    "page": 1,
    "pageSize": 20,
    "total": 145,
    "totalPages": 8
  }
}
```

****Error (4xx/5xx):****

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Deskripsi error dalam Bahasa Indonesia",
    "details": [
      { "field": "email", "message": "Email tidak valid" }
    ],
    "requestId": "uuid-untuk-tracing"
  }
}
```

1.4 HTTP Status Codes

Code	Meaning
200	OK
201	Created

1.5 Rate Limiting

- Auth endpoints (login, register): 5 requests / 15 menit per IP
- General API: 100 requests / menit per user
- Upload: 20 requests / menit per user
- Response header: `X-RateLimit-Limit`, `X-RateLimit-Remaining`, `X-RateLimit-Reset`

1.6 Standard Query Parameters (List Endpoints)

Param	Type	Default	Description
`page`	int	1	Page number
`pageSize`	int	20	Items per page (max 100)
`search`	string	-	Full-text search
`sort`	string	`-createdAt`	Sort field (prefix `-` for desc)
`from`	ISO date	-	Filter dari tanggal
`to`	ISO date	-	Filter sampai tanggal

2. Authentication Endpoints

2.1 POST `/api/auth/callback/credentials`

Login dengan email/password (NextAuth credentials provider).

****Request Body:****

```
{
  "email": "user@company.com",
  "password": "SecretPassword123!",
  "csrfToken": "..."}
}
```

****Response:**** Set HTTP-only cookie, redirect ke `/`.

****Error 401:****

```
{
```

```
"error": {
  "code": "INVALID_CREDENTIALS",
  "message": "Email atau password salah"
}
}

**Error 423 (Locked):**
{
  "error": {
    "code": "ACCOUNT_LOCKED",
    "message": "Akun terkunci. Coba lagi dalam 12 menit."
  }
}
```

2.2 POST `/api/auth/signout`

Logout dan hapus session cookie.

2.3 GET `/api/auth/session`

Ambil session saat ini.

****Response 200:****

```
{
  "user": {
    "id": "abc123",
    "email": "user@company.com",
    "name": "Budi",
    "role": "ENGINEER"
  },
  "expires": "2026-08-06T16:00:00.000Z"
}
```

2.4 POST `/api/auth/refresh`

Refresh JWT token (jika mendekati expiry).

3. Change Log Endpoints

3.1 GET `/api/change-logs`

List change logs dengan filter, search, pagination.

****Query Parameters:****

Param	Type	Description
`page`	int	Page number
`pageSize`	int	Items per page
`search`	string	Search di ticketId, deviceName, description
`deviceTypeId`	string	Filter by device type
`riskLevel`	enum	LOW, MEDIUM, HIGH, CRITICAL
`status`	enum	

****Response 200:****

```
{
  "data": [
    {
      "id": "clx123...",
      "ticketId": "CHG-2026-0001",
      "deviceType": { "id": "...", "name": "Switch" },
      "deviceName": "SW-CORE-01",
      "deviceIp": "10.0.0.1",
      "changeType": "ACL",
      "riskLevel": "MEDIUM",
      "status": "IMPLEMENTED",
      "pic": { "id": "...", "name": "Budi" },
      "implementedAt": "2026-08-06T10:30:00.000Z",
      "createdAt": "2026-08-06T10:35:00.000Z",
      "screenshotCount": 2
    }
  ],
  "meta": { "page": 1, "pageSize": 20, "total": 145, "totalPages": 8 }
}
```

3.2 POST `/api/change-logs`

Buat change log baru. ****Engineer+ only.****

****Request Body:****

```
{
  "deviceTypeId": "dev_001",
  "deviceName": "SW-CORE-01",
  "deviceIp": "10.0.0.1",
  "changeType": "ACL",
  "descriptionBefore": "ACL 100 permit tcp any any eq 80",
  "descriptionAfter": "ACL 100 permit tcp any any eq 80\nACL 101 deny tcp any any eq 23",
  "reason": "Menutup akses Telnet dari jaringan publik untuk kepatuhan PCI-DSS",
  "riskLevel": "MEDIUM",
  "rollbackPlan": "Hapus ACL 101 dan kembalikan ke konfigurasi sebelumnya",
  "implementedAt": "2026-08-06T10:30:00.000Z",
  "screenshots": [
    { "id": "scr_001", "type": "BEFORE" },
    { "id": "scr_002", "type": "AFTER" }
  ]
}
```

****Response 201:****

```
{
  "data": {
    "id": "clx...",
    "ticketId": "CHG-2026-0002",
    "status": "IMPLEMENTED",
    ...
  }
}
```

****Validation Errors (400):****

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "details": [
      { "field": "deviceName", "message": "Nama perangkat wajib diisi" },
      { "field": "descriptionBefore", "message": "Deskripsi sebelum wajib diisi" }
    ]
  }
}
```

3.3 GET `/api/change-logs/:id`

Detail change log lengkap dengan screenshots.

****Response 200:****

```
{
  "data": {
    "id": "clx...",
    "ticketId": "CHG-2026-0001",
    "deviceType": { "id": "...", "name": "Switch" },
    ...
  }
}
```

```

"deviceName": "SW-CORE-01",
"deviceIp": "10.0.0.1",
"changeType": "ACL",
"descriptionBefore": "...",
"descriptionAfter": "...",
"reason": "...",
"riskLevel": "MEDIUM",
"status": "IMPLEMENTED",
"pic": { "id": "...", "name": "Budi" },
"rollbackPlan": "...",
"implementedAt": "2026-08-06T10:30:00.000Z",
"verifiedAt": null,
"screenshots": [
  {
    "id": "scr_001",
    "type": "BEFORE",
    "url": "/api/files/screenshots/scr_001",
    "originalName": "before-acl.png",
    "size": 234567,
    "mimeType": "image/png"
  }
],
"deleteRequest": null,
"auditTrails": [
  {
    "action": "CREATE_CHANGE_LOG",
    "user": { "id": "...", "name": "Budi" },
    "timestamp": "2026-08-06T10:35:00.000Z"
  }
]
}
}

```

3.4 PATCH `/api/change-logs/:id`

Update change log. **Hanya jika status DRAFT atau user adalah Admin.**

Request Body (partial): Same fields as POST.

Response 200: Updated change log.

3.5 DELETE `/api/change-logs/:id`

Tidak tersedia langsung. Penghapusan harus melalui Delete Request workflow (lihat endpoint 4).

Jika dipanggil, response 405:

```

{
  "error": {
    "code": "METHOD_NOT_ALLOWED",
    "message": "Penghapusan change log harus melalui delete request. Lihat /api/delete-requests"
  }
}

```

3.6 POST `/api/change-logs/:id/verify`

Verifikasi change log (ubah status ke VERIFIED). **Supervisor+ only.**

Response 200:

```
{ "data": { "id": "...", "status": "VERIFIED", "verifiedAt": "...", "verifiedBy": {...} } }
```

4. Delete Request Endpoints

4.1 GET `/api/delete-requests`

List delete requests.

Query Parameters:

Param	Description
`status`	PENDING, APPROVED, REJECTED
`requestedById`	Filter by requester
`page` `pageSize`	

****Response 200:****

```
{
  "data": [
    {
      "id": "drq...",
      "changeLog": { "id": "...", "ticketId": "CHG-2026-0001", "deviceName": "...", },
      "requestedBy": { "id": "...", "name": "Budi" },
      "reason": "Salah input device, perlu dibuat ulang",
      "status": "PENDING",
      "createdAt": "2026-08-06T11:00:00.000Z"
    }
  ],
  "meta": { ... }
}
```

4.2 POST `/api/delete-requests`

Ajukan penghapusan. ****Engineer+ only.****

****Request Body:****

```
{
  "changeLogId": "clx...",
  "reason": "Salah input device, perlu dibuat ulang"
}
```

****Response 201:**** Delete request object.

****Error 409 (Conflict):****

```
{
  "error": {
    "code": "PENDING_REQUEST_EXISTS",
    "message": "Sudah ada request penghapusan pending untuk change log ini"
  }
}
```

4.3 POST `/api/delete-requests/:id/approve`

Approve penghapusan. ****Supervisor+ only.****

****Request Body:****

```
{
  "note": "Disetujui, memang salah input"
}
```

****Response 200:****

```
{
  "data": {
    "id": "drq...",
    "status": "APPROVED",
    "approvedBy": { "id": "...", "name": "Supervisor Andi" },
    "approvedAt": "2026-08-06T11:30:00.000Z",
    "changeLog": { "id": "...", "isDeleted": true, "deletedAt": "..." }
  }
}
```

4.4 POST `/api/delete-requests/:id/reject`

Reject penghapusan. ****Supervisor+ only.****

****Request Body:****

```
{
  "note": "Change log ini masih relevan untuk audit, tidak boleh dihapus"
}
```

4.5 POST `/api/change-logs/:id/restore`

Restore change log yang sudah soft-deleted. ****Admin only.****

5. File Upload Endpoints

5.1 POST `/api/upload`

Upload screenshot. ****Engineer+ only.**** Max 10MB per file.

****Request:**** `multipart/form-data`

file: <binary>

type: BEFORE | AFTER | OTHER

****Response 201:****

```
{
  "data": {
    "id": "scr_001",
    "filename": "abc123-def456.png",
    "originalName": "screenshot.png",
    "mimeType": "image/png",
    "size": 234567,
    "type": "BEFORE",
    "url": "/api/files/screenshots/scr_001"
  }
}
```

****Error 400 (Invalid file):****

```
{
  "error": {
    "code": "INVALID_FILE",
    "message": "File type tidak diizinkan. Hanya PNG, JPEG, WEBP, PDF."
  }
}
```

****Error 413 (File too large):****

```
{
  "error": {
    "code": "FILE_TOO_LARGE",
    "message": "Ukuran file melebihi 10MB"
  }
}
```

5.2 GET `/api/files/screenshots/:id`

Serve screenshot file. ****Authenticated users only.****

****Response 200:**** File binary dengan Content-Type sesuai.

5.3 DELETE `/api/files/screenshots/:id`

Hapus screenshot. ****Owner or Admin only.****

6. User Management Endpoints (Admin only)

6.1 GET `/api/admin/users`

List users.

6.2 POST `/api/admin/users`

Create new user.

****Request Body:****

```
{
  "email": "user@company.com",
  "name": "Budi",
  "password": "InitialPassword123!",
  "role": "ENGINEER",
  "ldapDn": null
}
```

6.3 PATCH `/api/admin/users/:id`

Update user (name, role, isActive, password reset).

6.4 POST `/api/admin/users/:id/deactivate`

Deactivate user (soft delete).

6.5 POST `/api/admin/users/:id/activate`

Reactivate user.

6.6 POST `/api/auth/change-password`

User changes own password.

****Request Body:****

```
{
```

```
"currentPassword": "OldPassword123!",
"newPassword": "NewPassword456@"
}
```

7. Device Type Endpoints

7.1 GET `/api/device-types`

List active device types. ****All authenticated users.****

7.2 POST `/api/admin/device-types`

Create new device type. ****Admin only.****

7.3 PATCH `/api/admin/device-types/:id`

Update device type.

7.4 POST `/api/admin/device-types/:id/deactivate`

Soft-disable device type.

8. Settings Endpoints (Admin only)

8.1 GET `/api/admin/settings`

Get all system settings.

8.2 PATCH `/api/admin/settings`

Update settings.

****Request Body:****

```
{
  "system.name": "CyberSec ChangeLog",
  "system.defaultTheme": "dark"
}
```

8.3 POST `/api/admin/settings/logo`

Upload custom logo. ****Admin only.**** Max 2MB, PNG/SVG.

****Request:**** `multipart/form-data`

file: <binary>

8.4 DELETE `/api/admin/settings/logo`

Reset ke default logo.

9. Dashboard Endpoints

9.1 GET `/api/dashboard/stats`

Statistik untuk dashboard.

****Response 200:****

```
{
  "data": {
    "totalChangeLogs": 145,
    "thisMonth": 23,
    "lastMonth": 18,
    "byDeviceType": [
      { "deviceType": "Switch", "count": 60 },
      { "deviceType": "Router MikroTik", "count": 45 },
      ...
    ],
    "byRiskLevel": {
      "LOW": 80, "MEDIUM": 50, "HIGH": 12, "CRITICAL": 3
    },
    "byStatus": {
      "IMPLEMENTED": 130, "VERIFIED": 10, "DRAFT": 5, "FAILED": 0
    },
    "byPic": [
      { "user": { "id": "...", "name": "Budi" }, "count": 40 }
    ],
  },
}
```

```

    "trend30Days": [
      { "date": "2026-07-08", "count": 3 },
      ...
    ],
    "pendingDeleteRequests": 2,
    "recentActivity": [
      {
        "action": "CREATE_CHANGE_LOG",
        "user": { "name": "Budi" },
        "entityType": "ChangeLog",
        "timestamp": "... "
      }
    ]
  }
}

```

9.2 GET `/api/audit-trail`

List audit trail. ****Supervisor+ only**** (Engineer hanya own).

10. Export Endpoints

10.1 GET `/api/export/excel`

Export list change logs ke Excel (.xlsx).

****Query:**** Same as `/api/change-logs` (filter aktif).

****Response 200:****

- Content-Type: `application/vnd.openxmlformats-officedocument.spreadsheetml.sheet`
- Content-Disposition: `attachment; filename="change-logs-2026-08-06.xlsx"`
- Binary XLSX content

****Excel Structure:****

- Sheet 1: "Change Logs" — kolom: Ticket ID, Date, Device Type, Device Name, IP, Change Type, Risk, Status, PIC, Description
- Sheet 2: "Summary" — pivot count by device type, risk level, status

10.2 GET `/api/export/pdf/:id`

Export single change log ke PDF.

****Response 200:****

- Content-Type: `application/pdf`
- Content-Disposition: `attachment; filename="CHG-2026-0001.pdf"`

****PDF Structure:****

- Header: System name, Logo, Ticket ID
- Section 1: Change Info (device, type, PIC, date, risk, status)
- Section 2: Description (before/after)
- Section 3: Reason & Rollback Plan
- Section 4: Screenshots (embedded images)
- Footer: Generated timestamp, page number

10.3 GET `/api/export/audit-trail/excel`

Export audit trail. ****Supervisor+ only****

11. Health Check

11.1 GET `/api/health`

Public endpoint untuk monitoring.

****Response 200:****

```

{
  "status": "ok",
  "timestamp": "2026-08-06T03:00:00.000Z",
  "uptime": 3600,
  "db": "connected",
  "version": "1.0.0"
}

```

****Response 503:**** Saat DB tidak terhubung.

12. Error Code Reference

Code	HTTP	Description
`VALIDATION_ERROR`	400	Input tidak valid
`INVALID_CREDENTIALS`	401	Email/password salah
`ACCOUNT_LOCKED`	423	Akun terkunci karena brute force
`ACCOUNT_DEACTIVATED`	403	Akun nonaktif
`UNAUTHORIZED`	401	Tidak login
`FORBIDDEN`	403	Tidak punya role cukup
`NOT_FOUND`	404	Resource tidak ditemukan
`CONFLICT`	409	Duplikat atau conflict
`PENDING_REQUEST_EXISTS`	409	Sudah ada delete request pending
`INVALID_FILE`	400	File type tidak diizinkan
`FILE_TOO_LARGE`	413	File melebihi size limit
`RATE_LIMIT_EXCEEDED`	429	Terlalu banyak request
`INTERNAL_ERROR`	500	

13. WebSocket / Real-time (Future)

Tidak ada di MVP. Untuk v2 mungkin:

- Real-time notification delete request baru ke supervisor
 - Live dashboard updates
-

Security & OWASP Compliance Document

SecChangeLog — Sistem Pencatatan Perubahan Konfigurasi

Field	Value
Document Version	1.0.0
Status	Final
Last Updated	2026-08-06
Standard Reference	OWASP Top 10 (2021), OWASP ASVS v4.0.3 Level 2

1. Pendekatan Security by Design

SecChangeLog dibangun dengan prinsip ****Defense in Depth****: setiap layer memiliki kontrol keamanan sendiri, sehingga kegagalan di satu layer tidak langsung mengakibatkan breach.

[illegible]

2. OWASP Top 10 (2021) Compliance Matrix

A01:2021 — Broken Access Control

Control	Implementation
RBAC enforced server-side	Setiap API route cek role via `requireRole()` helper
Deny by default	Middleware redirect ke `/login` jika tidak authenticated
Resource ownership check	Engineer hanya bisa edit change log yang dia buat
Disable directory listing	Next.js static serving tidak list direktori
Invalidate session after logout	

****Code example:****

```
// src/lib/auth-options.ts
async function authorize(credentials) {
  // 1. Rate limit check
  // 2. Account lockout check
  // 3. Verify password (bcrypt.compare)
  // 4. Check user.isActive
  // 5. Update lastLoginAt, lastLoginIp
  // 6. Write audit trail LOGIN_SUCCESS or LOGIN_FAILED
  // 7. Return user object (without passwordHash)
}
```

A02:2021 — Cryptographic Failures '

Control	Implementation
Password hashing	bcrypt cost factor 12 ("H 250ms per hash)
No sensitive data in URL	Semua data sensitif via POST body
HTTPS-only in production	HSTS header, redirect HTTP !' HTTPS
LDAP bind password encryption	AES-256-GCM dengan key dari env var
Session token	JWT signed dengan `NEXTAUTH_SECRET` (32+ random bytes)
No sensitive data in logs	Logger redact password, token, email di log
Database encryption at rest	MySQL InnoDB encryption atau disk LUKS

A03:2021 — Injection '

Control	Implementation
SQL Injection	Prisma ORM dengan parameterized queries (default safe)
NoSQL Injection	Tidak menggunakan NoSQL
OS Command Injection	Tidak ada `exec()` atau `spawn()` dengan user input
LDAP Injection	LDAP query menggunakan escaping library (`ldap-escape`)
Template Injection	React auto-escaping + tidak menggunakan

****Prisma safe query example:****

```
// ' SAFE - Prisma parameterizes
const user = await db.user.findUnique({ where: { id: userId } });
// ' SAFE - Raw query with tagged template
const result = await db.$queryRaw`SELECT * FROM User WHERE email = ${email}`;
// 'L FORBIDDEN - String concatenation
const result = await db.$queryRaw(`SELECT * FROM User WHERE email = '${email}'`);
```

A04:2021 — Insecure Design '

Control	Implementation
Threat modeling	Dilakukan sebelum coding (lihat dokumen ini)
Secure design patterns	Layered architecture, principle of least privilege
Fail secure	Default deny; error tidak expose info
Separation of duties	Delete butuh approval supervisor
Business logic validation	Status workflow tidak bisa di-skip
Audit trail	Semua aksi tercatat untuk forensik

A05:2021 — Security Misconfiguration '

Control	Implementation
No default credentials	Seed admin password adalah random generated
Disable unused features	Next.js experimental features dinonaktifkan
Security headers	Lihat daftar lengkap di bawah
Error handling	Tidak expose stack trace di production
Disable X-Powered-By	`poweredByHeader: false` di next.config
CORS restrict	Same-origin only (tidak ada cross-origin API)
DB credentials	Dari env var, tidak hardcoded

A06:2021 — Vulnerable and Outdated Components '

Control	Implementation
Dependency audit	`bun audit` di CI/CD
Lock file	`bun.lock` committed
No unpinned versions	Semua dependency pinned di package.json
Subscribe to security advisories	GitHub Dependabot di-enable
Update policy	Patch version: langsung; Minor: review; Major: planning

A07:2021 — Identification and Authentication Failures '

Control	Implementation
bcrypt password hashing	Cost factor 12
Password policy	Min 10 char, uppercase, lowercase, number, symbol
Account lockout	5 percobaan gagal !' lock 15 menit
Session timeout	8 jam (configurable via settings)
Session invalidation	Logout menghapus cookie + server session
No session in URL	Hanya via httpOnly cookie
Rotate session after login	NextAuth generate token baru
MFA (future)	Out of scope MVP, target v2

A08:2021 — Software and Data Integrity Failures '

Control	Implementation
No untrusted deserialization	Tidak menggunakan `eval()`, `Function()`, atau `unserialize()`

A09:2021 — Security Logging and Monitoring Failures '

Control	Implementation
Audit trail	Semua aksi tercatat di tabel AuditTrail
Login attempts	LOGIN_SUCCESS dan LOGIN_FAILED tercatat
Privileged actions	Admin actions tercatat dengan IP dan user agent
Log format	Structured JSON, no sensitive data
Log retention	7 tahun (compliance)
Alerting (future)	Out of scope MVP, target v2 (SIEM integration)

A10:2021 — Server-Side Request Forgery (SSRF) '

Control	Implementation
No URL fetch from user input	Tidak ada fitur "fetch URL from server"
LDAP URL whitelist	LDAP server URL hanya bisa di-set oleh Admin
Image URL	Hanya serve dari local filesystem (tidak proxy remote)
Outbound connections	Hanya ke LDAP server (jika enabled), tidak ada outbound HTTP

3. Security Headers Configuration

Middleware Next.js akan inject header berikut ke setiap response:

```
# Force HTTPS
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
# Prevent clickjacking
X-Frame-Options: DENY
Content-Security-Policy: frame-ancestors 'none'
# Prevent MIME sniffing
X-Content-Type-Options: nosniff
# Referrer policy
Referrer-Policy: strict-origin-when-cross-origin
# Content Security Policy
Content-Security-Policy: default-src 'self';
  script-src 'self' 'unsafe-inline';
  style-src 'self' 'unsafe-inline';
```

```

img-src 'self' data: blob;;
font-src 'self';
connect-src 'self';
frame-ancestors 'none';
base-uri 'self';
form-action 'self';
# Permissions policy
Permissions-Policy: camera=(), microphone=(), geolocation=()
# Remove server fingerprint
X-Powered-By: (removed)
Server: (removed)

```

4. Authentication Security Deep-Dive

4.1 Password Storage

```

[User Input: "MyPassword123!"]
! "
[bcrypt.hash(password, 12)] ! ' $2b$12$N9qo8uL0ickgx2ZMRZoMye...
! "
[Stored in DB: passwordHash column]

**Verifikasi:**
[User Input: "MyPassword123!"]
! "
[bcrypt.compare(input, storedHash)] ! ' true / false

```

4.2 Account Lockout Mechanism

```

async function handleFailedLogin(email: string, ip: string) {
  await db.user.update({
    where: { email },
    data: { failedAttempts: { increment: 1 } }
  });

  const user = await db.user.findUnique({ where: { email } });

  if (user.failedAttempts >= 5) {
    await db.user.update({
      where: { email },
      data: {
        failedAttempts: 0,
        lockedUntil: new Date(Date.now() + 15 * 60 * 1000) // 15 menit
      }
    });

    await auditTrail.log({
      action: 'ACCOUNT_LOCKED',
      userId: user.id,
      metadata: { reason: 'Too many failed attempts', ip }
    });
  }
}

```

4.3 LDAP Authentication Flow

1. User submit email + password
2. Cek apakah user ada di local DB
 - %%% Jika ada dan passwordHash "` null !" verifikasi local
 - %%% Jika ada dan ldapDn "` null !" bind ke LDAP dengan user DN
3. Jika user tidak ada di local DB:
 - %%% Cari di LDAP berdasarkan searchFilter
 - %%% Jika ditemukan !" bind dengan password
 - %%% Jika bind sukses !" auto-create user lokal dengan role default 'ENGINEER'
4. Update lastLoginAt, write audit trail
5. Generate JWT, set cookie

4.4 Session Token Security

- Algorithm: HS256
- Secret: `NEXTAUTH\_SECRET` (min 32 bytes random)
- Cookie attributes:
 - `httpOnly: true` (tidak bisa diakses JavaScript)

[illegible]

```
// src/lib/validations/change-log.ts
import { z } from 'zod';
export const createChangeLogSchema = z.object({
  deviceId: z.string().cuid(),
  deviceName: z.string().min(1, 'Nama perangkat wajib diisi').max(100),
});
```

```

deviceIp: z.string().ip().optional().or(z.literal('')),
changeType: z.enum([
  'ACL', 'ROUTING', 'NAT', 'INTERFACE',
  'SECURITY_POLICY', 'VPN', 'OTHER'
]),
descriptionBefore: z.string().min(10, 'Deskripsi sebelum minimal 10 karakter').max(5000),
descriptionAfter: z.string().min(10, 'Deskripsi setelah minimal 10 karakter').max(5000),
reason: z.string().min(10, 'Alasan minimal 10 karakter').max(2000),
riskLevel: z.enum(['LOW', 'MEDIUM', 'HIGH', 'CRITICAL']),
rollbackPlan: z.string().max(2000).optional(),
implementedAt: z.string().datetime(),
screenshots: z.array(z.object({
  id: z.string().cuid(),
  type: z.enum(['BEFORE', 'AFTER', 'OTHER'])
})).max(10, 'Maksimal 10 screenshot')
});
export type CreateChangeLogInput = z.infer<typeof createChangeLogSchema>;

```

6.2 Server-Side Enforcement

```

// src/app/api/change-logs/route.ts
export async function POST(req: Request) {
  const session = await getSession();
  if (!session) return unauthorized();
  if (!['ENGINEER', 'SUPERVISOR', 'ADMIN'].includes(session.user.role)) {
    return forbidden();
  }

  const body = await req.json();
  const parsed = createChangeLogSchema.safeParse(body);

  if (!parsed.success) {
    return validationError(parsed.error.flatten());
  }

  // Service layer akan cek deviceId exists, etc.
  const result = await ChangeLogService.create(parsed.data, session.user.id);
  return created(result);
}

```

7. CORS Policy

```

// next.config.ts
const nextConfig = {
  async headers() {
    return [{
      source: '/api/:path*',
      headers: [
        { key: 'Access-Control-Allow-Origin', value: process.env.NODE_ENV === 'production' ? 'https://yourdomain.com' : '*' },
        { key: 'Access-Control-Allow-Methods', value: 'GET, POST, PATCH, DELETE, OPTIONS' },
        { key: 'Access-Control-Allow-Headers', value: 'Content-Type, Authorization' },
        { key: 'Access-Control-Allow-Credentials', value: 'true' },
        { key: 'Access-Control-Max-Age', value: '86400' }
      ]
    }];
  }
};

```

> ****MVP****: Same-origin only (tidak ada CORS preflight needed). CORS headers tetap di-set untuk future-proofing.

8. Rate Limiting Implementation

```

// src/lib/security/rate-limit.ts
const RATE_LIMITS = {
  LOGIN: { requests: 5, window: 15 * 60 * 1000 }, // 5 / 15 min
  API: { requests: 100, window: 60 * 1000 }, // 100 / min
  UPLOAD: { requests: 20, window: 60 * 1000 } // 20 / min
};
// In-memory store (single instance only)
const store = new Map<string, { count: number; resetAt: number }>();

```

```

export function rateLimit(
  key: string,
  config: { requests: number; window: number }
): { allowed: boolean; remaining: number; resetAt: number } {
  const now = Date.now();
  const record = store.get(key);

  if (!record || record.resetAt < now) {
    store.set(key, { count: 1, resetAt: now + config.window });
    return { allowed: true, remaining: config.requests - 1, resetAt: now + config.window };
  }

  if (record.count >= config.requests) {
    return { allowed: false, remaining: 0, resetAt: record.resetAt };
  }

  record.count++;
  return { allowed: true, remaining: config.requests - record.count, resetAt: record.resetAt };
}

```

> **Production note**: Untuk multi-instance deployment, ganti ke Redis-based rate limiter.

9. Audit Trail Implementation

Setiap operasi penting menulis ke AuditTrail:

```

// src/lib/services/audit-trail.service.ts
export class AuditTrailService {
  static async log(params: {
    userId: string;
    action: string;
    entityType: string;
    entityId: string;
    metadata?: Record<string, unknown>;
    ipAddress?: string;
    userAgent?: string;
  }) {
    await db.auditTrail.create({
      data: {
        userId: params.userId,
        action: params.action,
        entityType: params.entityType,
        entityId: params.entityId,
        metadata: params.metadata || {},
        ipAddress: params.ipAddress,
        userAgent: params.userAgent
      }
    });
  }
}

// Usage di service:
await AuditTrailService.log({
  userId: session.user.id,
  action: 'CREATE_CHANGE_LOG',
  entityType: 'ChangeLog',
  entityId: changeLog.id,
  metadata: { ticketId: changeLog.ticketId, deviceName: changeLog.deviceName },
  ipAddress: request.headers.get('x-forwarded-for'),
  userAgent: request.headers.get('user-agent')
});

```

10. Penetration Testing Checklist

Sebelum production release, lakukan testing berikut:

10.1 Authentication

- [] Brute force login dengan 100 percobaan !' akun terkunci setelah 5
- [] Login dengan password salah !' failedAttempts increment
- [] Lockout expiry !' akun bisa login lagi setelah 15 menit

- [] Session fixation attack !' session berubah setelah login
- [] JWT tampering !' invalid signature ditolak
- [] Logout !' session benar-benar invalid

10.2 Authorization

- [] Engineer mencoba akses `/api/admin/\*` !' 403
- [] Engineer mencoba edit change log orang lain !' 403
- [] Engineer mencoba approve delete request !' 403
- [] Manipulasi role di JWT !' signature invalid
- [] IDOR: ganti ID di URL !' akses ditolak jika bukan owner

10.3 Input Validation

- [] Submit form dengan field kosong !' validation error
- [] Submit dengan string sangat panjang (10000 char) !' ditolak
- [] Submit dengan HTML `

- `NEXTAUTH\_SECRET`: rotasi tahunan (invalidate semua session)
- `LDAP\_ENCRYPTION\_KEY`: rotasi 2 tahunan
- DB password: rotasi 6 bulanan

12. Compliance Mapping

12.1 ISO 27001:2022

Control	Implementation
A.5.16 Identity management	User lifecycle via admin panel
A.5.17 Authentication information	bcrypt + password policy
A.5.18 Access rights	RBAC + least privilege
A.8.9 Configuration management	Core feature of SecChangeLog
A.8.15 Logging	AuditTrail table
A.8.16 Monitoring activities	AuditTrail + dashboard
A.8.23 Web filtering	N/A (internal system)
A.8.28 Secure coding	OWASP compliance, this document

12.2 PCI-DSS v4.0

Requirement	Implementation
7.2 Role-based access control	RBAC implemented
8.3 Authentication factors	Username/password + future MFA
10.2 Audit trails	AuditTrail table, 7-year retention
10.4 Sync time	NTP di server
11.3 Penetration testing	Checklist di atas

13. Incident Response Plan

13.1 Security Incident Categories

- 1. **Critical**: Data breach, unauthorized admin access
- 2. **High**: Brute force success, file upload bypass
- 3. **Medium**: Rate limit violation, suspicious activity
- 4. **Low**: Failed login attempts

13.2 Response Steps

- 1. **Detect**: Audit trail monitoring, alert threshold
- 2. **Contain**: Disable account, block IP, revoke sessions
- 3. **Eradicate**: Patch vulnerability, remove malicious data
- 4. **Recover**: Restore dari backup jika perlu
- 5. **Lessons learned**: Post-mortem, update security policy

13.3 Contact

- Security Team Lead: [TBD]
- IT Manager: [TBD]
- Incident Response: [TBD]

14. Security Maintenance Tasks

Task	Frequency	Owner
Dependency audit (`bun audit`)	Weekly	DevOps
Penetration testing	Quarterly	External
Security review	Monthly	Tech Lead
Password rotation (admin)	Quarterly	Admin
Backup verification	Monthly	DevOps
Log review	Daily	Security Analyst
SSL certificate renewal	30 days before expiry	DevOps

Deployment & Operations Guide

SecChangeLog

Field	Value
Document Version	1.0.0
Status	Final
Last Updated	2026-08-06

1. Prasyarat Sistem

1.1 Hardware Minimum (Production)

- **CPU**: 2 cores
- **RAM**: 4 GB
- **Disk**: 50 GB SSD (untuk aplikasi + uploads + backup)
- **Network**: 100 Mbps

1.2 Software Requirements

- **OS**: Ubuntu 22.04 LTS atau Debian 12
- **Node.js**: 20.x LTS
- **Bun**: 1.1+ (untuk build & runtime)
- **MySQL**: 8.0+
- **Nginx/Caddy**: untuk reverse proxy & SSL termination

1.3 Ports

Port	Purpose
3000	Next.js application
3306	MySQL (internal only, tidak expose ke publik)
80/443	Nginx (HTTP/HTTPS)

2. Environment Variables

2.1 Development (.env)

```
# Database
DATABASE_URL="file:./db/dev.db" # SQLite untuk dev
# atau
# DATABASE_URL="mysql://user:pass@localhost:3306/secchangelog_dev"
# NextAuth
NEXTAUTH_SECRET="dev-secret-change-in-production-min-32-chars"
```

```
NEXTAUTH_URL="http://localhost:3000"
# LDAP Encryption Key (untuk encrypt LDAP bind password di DB)
LDAP_ENCRYPTION_KEY="dev-encryption-key-change-in-production"
# File Upload
UPLOAD_DIR="/home/z/my-project/public/uploads"
MAX_FILE_SIZE_MB=10
# App
NODE_ENV="development"
```

2.2 Production (.env.production) — JANGAN commit ke repo

```
# Database
DATABASE_URL="mysql://secchangelog:STRONG_PASSWORD@localhost:3306/secchangelog"
# NextAuth (generate: openssl rand -base64 32)
NEXTAUTH_SECRET="PRODUCTION_SECRET_32_CHARS_RANDOM"
NEXTAUTH_URL="https://changelog.company.com"
# LDAP Encryption
LDAP_ENCRYPTION_KEY="PRODUCTION_ENCRYPTION_KEY_32_CHARS"
# File Upload
UPLOAD_DIR="/var/www/secchangelog/uploads"
MAX_FILE_SIZE_MB=10
# App
NODE_ENV="production"
```

3. Installation Steps (Production)

3.1 Clone Repository

```
cd /var/www
git clone https://github.com/your-org/secchangelog.git
cd secchangelog
```

3.2 Install Dependencies

```
bun install --frozen-lockfile
```

3.3 Setup Environment

```
cp .env.example .env.production
# Edit .env.production dengan nilai production
nano .env.production
```

3.4 Generate Secrets

```
# NEXTAUTH_SECRET
openssl rand -base64 32
# LDAP_ENCRYPTION_KEY
openssl rand -base64 32
# DB password
openssl rand -base64 24
```

3.5 Setup MySQL Database

```
mysql -u root -p

CREATE DATABASE secchangelog CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;
CREATE USER 'secchangelog'@'localhost' IDENTIFIED BY 'STRONG_PASSWORD';
GRANT ALL PRIVILEGES ON secchangelog.* TO 'secchangelog'@'localhost';
FLUSH PRIVILEGES;
EXIT;
```

3.6 Update Prisma Schema untuk MySQL

```
Edit `prisma/schema.prisma`:
datasource db {
  provider = "mysql"
  url      = env("DATABASE_URL")
}
```

3.7 Run Migration

```
bun run db:migrate --name init
bun run db:generate
```

3.8 Seed Initial Admin

```
bun run scripts/seed-admin.ts
# Output: Admin user created
```

```
# Email: admin@company.com
# Password: <random-generated-displayed-once>
```

3.9 Build Application

```
bun run build
```

3.10 Setup Process Manager (PM2)

```
npm install -g pm2
pm2 start "bun .next/standalone/server.js" --name secchangelog
pm2 startup
pm2 save
```

3.11 Setup Nginx Reverse Proxy

```
# /etc/nginx/sites-available/secchangelog
server {
    listen 80;
    server_name changelog.company.com;
    return 301 https://$server_name$request_uri;
}
server {
    listen 443 ssl http2;
    server_name changelog.company.com;
    # SSL
    ssl_certificate /etc/letsencrypt/live/changelog.company.com/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/changelog.company.com/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_ciphers HIGH:!aNULL:!MD5;
    # Security headers
    add_header Strict-Transport-Security "max-age=63072000; includeSubDomains; preload" always;
    add_header X-Frame-Options "DENY" always;
    add_header X-Content-Type-Options "nosniff" always;
    # Upload size
    client_max_body_size 12M;
    # Reverse proxy
    location / {
        proxy_pass http://127.0.0.1:3000;
        proxy_http_version 1.1;
        proxy_set_header Upgrade $http_upgrade;
        proxy_set_header Connection 'upgrade';
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
        proxy_cache_bypass $http_upgrade;
    }
    # Static files (Next.js)
    location /_next/static/ {
        alias /var/www/secchangelog/.next/static/;
        expires 1y;
        add_header Cache-Control "public, immutable";
    }
}

ln -s /etc/nginx/sites-available/secchangelog /etc/nginx/sites-enabled/
nginx -t
systemctl reload nginx
```

3.12 Setup SSL dengan Let's Encrypt

```
certbot --nginx -d changelog.company.com
```

3.13 Setup Backup Cron

```
# /etc/cron.d/secchangelog-backup
0 2 * * * root /var/www/secchangelog/scripts/backup.sh
```

4. Deployment Workflow

4.1 Standard Deployment

```
# 1. Pull latest code
cd /var/www/secchangelog
git pull origin main
```

```
# 2. Install dependencies
bun install --frozen-lockfile
# 3. Run migration (jika ada)
bun run db:migrate deploy
# 4. Build
bun run build
# 5. Restart app
pm2 restart secchangelog
# 6. Verify
curl https://changelog.company.com/api/health
```

4.2 Rollback

```
# 1. Find previous commit
git log --oneline -10
# 2. Checkout ke commit sebelumnya
git checkout <commit-hash>
# 3. Build & restart
bun install --frozen-lockfile
bun run build
pm2 restart secchangelog
# 4. Database rollback (jika perlu)
bun run prisma migrate resolve --rolled-back <migration-name>
```

5. Monitoring

5.1 Health Check

```
curl https://changelog.company.com/api/health
# Expected: {"status":"ok","db":"connected",...}
```

5.2 PM2 Monitoring

```
pm2 status secchangelog
pm2 logs secchangelog --lines 100
pm2 monit
```

5.3 Log Files

- Application: `pm2 logs secchangelog`
- Nginx access: `/var/log/nginx/access.log`
- Nginx error: `/var/log/nginx/error.log`
- MySQL: `/var/log/mysql/error.log`

5.4 Disk Usage (Uploads)

```
du -sh /var/www/secchangelog/public/uploads/
df -h
```

6. Backup & Restore

6.1 Backup Script

```
#!/bin/bash
# /var/www/secchangelog/scripts/backup.sh
DATE=$(date +%Y%m%d_%H%M%S)
BACKUP_DIR="/var/backups/secchangelog"
ENCRYPTION_KEY=$(cat /etc/secchangelog/backup-key)
mkdir -p $BACKUP_DIR
# Backup MySQL
mysqldump -u secchangelog -p$(cat /etc/secchangelog/db-password) \
  secchangelog | gzip | openssl enc -aes-256-cbc -salt -pass file:$ENCRYPTION_KEY \
  > $BACKUP_DIR/db_$DATE.sql.gz.enc
# Backup uploads
tar czf - /var/www/secchangelog/public/uploads/ | \
  openssl enc -aes-256-cbc -salt -pass file:$ENCRYPTION_KEY \
  > $BACKUP_DIR/uploads_$DATE.tar.gz.enc
# Keep only last 30 days
find $BACKUP_DIR -type f -mtime +30 -delete
# Optional: copy to offsite storage
# aws s3 cp $BACKUP_DIR/db_$DATE.sql.gz.enc s3://your-bucket/backups/
```

6.2 Restore Procedure

```
# 1. Decrypt database backup
openssl enc -d -aes-256-cbc -pass file:$ENCRYPTION_KEY \
-in db_20260806_020000.sql.gz.enc | gunzip > restore.sql
# 2. Stop application
pm2 stop secchangelog
# 3. Restore database
mysql -u secchangelog -p secchangelog < restore.sql
# 4. Restore uploads
openssl enc -d -aes-256-cbc -pass file:$ENCRYPTION_KEY \
-in uploads_20260806_020000.tar.gz.enc | tar xzf - -C /
# 5. Start application
pm2 start secchangelog
```

7. Post-Deployment Checklist

- [] Health check endpoint returns 200 OK
 - [] Login page accessible
 - [] Default admin can login with generated password
 - [] Create test change log !' berhasil
 - [] Upload screenshot !' berhasil, file tersimpan di uploads
 - [] Export Excel !' file diunduh
 - [] Export PDF !' file diunduh
 - [] Settings page !' bisa upload logo
 - [] HTTPS active (lock icon di browser)
 - [] Security headers cek di <https://securityheaders.com>
 - [] SSL certificate valid (cek di SSL Labs)
 - [] Backup cron berjalan (cek ``/var/backups/secchangelog/``)
 - [] PM2 auto-restart on crash (test dengan ``pm2 kill``)
 - [] Disk monitoring setup
-

8. Troubleshooting

8.1 Database Connection Error

```
# Cek koneksi
mysql -u secchangelog -p -e "SELECT 1"
# Cek log MySQL
tail -f /var/log/mysql/error.log
# Cek Prisma connection
cd /var/www/secchangelog
bun run prisma db execute --stdin <<< "SELECT 1;"
```

8.2 Upload Failed (413)

- Cek ``client_max_body_size`` di Nginx (harus "e 12M)
- Cek ``MAX_FILE_SIZE_MB`` di .env
- Cek disk space: ``df -h``

8.3 Login Failed

- Cek apakah akun terkunci (lihat di DB: ``lockedUntil``)
- Cek apakah user aktif (``isActive = true``)
- Cek log aplikasi: ``pm2 logs secchangelog | grep -i auth``

8.4 Export Timeout

- Tambah timeout di Nginx: ``proxy_read_timeout 300s;``
- Untuk dataset besar, implementasi async export (future)

8.5 LDAP Connection Failed

- Test dengan ``ldapsearch``:
```bash  
ldapsearch -H ldap://ldap.company.com:389 \  
-D "cn=admin,dc=company,dc=com" -W \  
-b "ou=users,dc=company,dc=com" "(sAMAccountName=testuser)"  
...  
• Cek firewall: port 389/636 terbuka dari app server
-

## 9. Maintenance Tasks

### 9.1 Daily

- Cek health endpoint
- Cek backup berhasil
- Cek disk usage

### 9.2 Weekly

- Cek slow query log MySQL
- Review audit trail untuk aktivitas suspicious
- Update dependency patch version

### 9.3 Monthly

- Rotate log files
- Test restore dari backup
- Security review (audit trail analysis)
- Renew SSL certificate (jika perlu)

### 9.4 Quarterly

- Penetration testing
  - Penetration testing follow-up
  - Dependency upgrade minor version
  - Review & cleanup deactivated users
- 

## 10. Performance Tuning

### 10.1 MySQL Configuration

```
/etc/mysql/conf.d/secchangelog.cnf
[mysqld]
innodb_buffer_pool_size = 1G # 25% dari total RAM
innodb_log_file_size = 256M
max_connections = 100
slow_query_log = 1
long_query_time = 2
```

### 10.2 PM2 Cluster Mode (untuk multi-core)

```
// ecosystem.config.js
module.exports = {
 apps: [{
 name: 'secchangelog',
 script: '.next/standalone/server.js',
 instances: 'max', // gunakan semua core
 exec_mode: 'cluster',
 max_memory_restart: '1G',
 env: { NODE_ENV: 'production' }
 }]
};
```

> **Catatan**: Untuk cluster mode, ganti in-memory rate limiter ke Redis-based.

### 10.3 Next.js Standalone Build

Pastikan `next.config.ts`:

```
const nextConfig = {
 output: 'standalone',
 // ...
};
```

---

## 11. Disaster Recovery

### 11.1 RPO & RTO

- **RPO** (Recovery Point Objective): "d 24 jam (daily backup)
- **RTO** (Recovery Time Objective): "d 4 jam

### 11.2 Recovery Steps



- 1. Provision server baru
- 2. Install dependencies (Node.js, Bun, MySQL, Nginx)
- 3. Restore database dari backup terakhir
- 4. Restore uploads dari backup
- 5. Deploy aplikasi
- 6. Update DNS ke server baru
- 7. Verify dengan health check & smoke test

11.3 Communication Plan

- Notify stakeholders dalam 30 menit setelah incident terdeteksi
- Update progress setiap 1 jam selama recovery
- Post-mortem dalam 48 jam setelah recovery

12. Contact Information

| Role             | Name  | Contact |
|------------------|-------|---------|
| Tech Lead        | [TBD] | [TBD]   |
| DevOps           | [TBD] | [TBD]   |
| Security Officer | [TBD] | [TBD]   |
| DBA              | [TBD] | [TBD]   |

## **Akhir Dokumentasi**

Untuk pertanyaan, hubungi tim Engineering.